

COMP-3018

Secure Coding and Testing

Final Project: Code Security Audit

Lichao Huang

04/19/2026

## Table of contents

1. Vulnerability: B404(manually introduce)

Page 3

2. Vulnerability: B112(original)

Page 4

3. Vulnerability: B602(manually introduce)

Page 5

4. Summary

Page 6

## Vulnerability: B404

**blacklist:** Consider possible security implications associated with the subprocess module.

**Test ID:** B404

**Severity:** LOW

**Confidence:** HIGH

**CWE:** [CWE-78](#)

**File:** [.src\chatbot.py](#)

**Line number:** 17

**More info:** [https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist\\_imports.html#b404-import-subprocess](https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b404-import-subprocess)

```
16
17     import subprocess
18
```

### Severity:

Low

### OWASP TOP 10:

A03 Injection

### Solution:

This is a manually introduced vulnerability designed to create a serious vulnerability when using subprocess in code. The use of the subprocess module is not inherently insecure but may introduce risks related to OWASP A03 if used improperly. **Removing this import** will resolve the vulnerability.

## Vulnerability: B112

**try\_except\_continue:** Try, Except, Continue detected.

**Test ID:** B112

**Severity:** LOW

**Confidence:** HIGH

**CWE:** [CWE-703](#)

**File:** [\src\chatbot.py](#)

**Line number:** 151

**More info:** [https://bandit.readthedocs.io/en/1.9.4/plugins/b112\\_try\\_except\\_continue.html](https://bandit.readthedocs.io/en/1.9.4/plugins/b112_try_except_continue.html)

```
150             task = get_task()
151         except:
152             continue
153         if task in VALID_TASKS:
```

### Severity:

Low

### OWASP TOP 10:

A09: Security Logging and Monitoring Failures

### Solution:

The code uses a bare except statement combined with a continue statement, which results in all exceptions being silently ignored. This practice prevents proper error handling and hides potential system failures.

The following code can be used to send error messages to the console when an error is detected.

try:

```
    task = get_task()
```

except Exception as e:

```
    logging.error("Error getting task", exc_info=True)
```

```
    continue
```

## Vulnerability: B604

```
subprocess_popen_with_shell_equals_true: subprocess call with shell=True identified, security issue.  
Test ID: B602  
Severity: HIGH  
Confidence: HIGH  
CWE: CWE-78  
File: .srcchatbot.py  
Line number: 182  
More info: https://bandit.readthedocs.io/en/1.9.4/plugins/b602\_subprocess\_popen\_with\_shell\_equals\_true.html  
  
181         cmd = input("Enter command: ")  
182         subprocess.call(cmd, shell=True)
```

### Severity:

High

### OWASP TOP 10:

A03 Injection

### Solution:

This vulnerability was intentionally introduced for testing purposes. The code uses the subprocess module with shell=True, allowing user input to be executed as system commands. This creates a command injection risk, where attackers can run arbitrary commands on the host system. The issue occurs due to lack of input validation and unsafe execution of external commands. To mitigate this risk, **shell=True should be avoided**.

## Summary:

Bandit detected a total of three vulnerabilities, including two low-severity issues and one high-severity issue. Among these, B602 should be addressed first, as it poses the greatest risk by allowing potential command injection; command-line access should not be exposed to unauthenticated users. B112 should be addressed next, as improper exception handling prevents effective monitoring and detection of errors. Finally, B404 can be addressed last; while it contributes to risk when combined with other issues, the use of the subprocess module itself is not inherently insecure.